

☒ Security Management Concepts & Principles

1. Confidentiality, Integrity, and Availability (CIA Triad)

- **Confidentiality:** Ensures data is only accessible to those with proper authorization.
- **Integrity:** Assures that data has not been altered in an unauthorized manner.
- **Availability:** Ensures that information and systems are accessible when needed.

2. Security Governance

- Strategic alignment of security with business objectives.
- Implementation of risk management, policy enforcement, and compliance.

3. Security Policies, Standards, Procedures

- **Policy:** High-level statement outlining security goals.
- **Standard:** Mandatory controls derived from policies.
- **Procedure:** Step-by-step instructions to meet standards.
- **Guideline:** Recommendations that are not mandatory.

4. Risk Management

- Risk Assessment: Identifying assets, threats, vulnerabilities, and controls.
 - Risk Treatment: Accept, avoid, mitigate, or transfer risk.
-

☒ Human Side of Information Security

1. Social Engineering

- Exploiting human psychology to gain unauthorized access.
- Types include phishing, baiting, pretexting, and tailgating.

2. Security Awareness Training

- Educates users about best practices and emerging threats.
- Encourages reporting of suspicious activities.

3. Insider Threats

- Malicious (disgruntled employees) or negligent insiders.
- Often harder to detect and more damaging.

4. User Behavior Analytics (UBA)

- Detects abnormal user behavior to identify potential threats.
-

☒ Threats to Information Systems

1. Natural Threats

- Floods, earthquakes, fires that affect infrastructure.

2. Technical Threats

- Malware, viruses, worms, ransomware, DDoS attacks.

3. Human Threats

- Hackers, insiders, social engineers.

4. Physical Threats

- Theft of hardware, unauthorized physical access.
-

☒ Threats and Attacks

1. Active vs Passive Attacks

- **Active:** Modify or disrupt data (e.g., DoS, MITM).
- **Passive:** Eavesdrop or monitor (e.g., sniffing, keylogging).

2. Common Attacks

- **Phishing:** Tricking users into revealing confidential data.
 - **SQL Injection:** Inserting malicious SQL code.
 - **Cross-Site Scripting (XSS):** Injecting scripts into trusted websites.
 - **Man-in-the-Middle (MITM):** Intercepting communication between parties.
-

☒ Classification of Threats and Attacks

1. By Source

- **Internal:** Originating from within the organization.
- **External:** From outside actors like hackers, competitors.

2. By Motivation

- Financial Gain: Cybercrime, ransomware.
- Political Reasons: Hacktivism, cyberterrorism.
- Espionage: Corporate or nation-state spying.

3. By Target

- Network-based: Attacks targeting infrastructure.
- Application-based: Targeting software and web apps.
- User-based: Targeting individuals (e.g., phishing).

4. By Technique

- Social Engineering
- Malware
- Brute Force
- Backdoors